

(a) MARCO INTEGRATIVO GQM + PRAGMATIC APLICADO A MARGA-ENS

1. Introducción

El presente marco integra dos enfoques complementarios:

- GQM (Goal–Question–Metric), que estructura la medición a partir de metas, preguntas y métricas. [web:41][web:45][web:50]
- PRAGMATIC, un metamétodo para evaluar la utilidad de cada métrica según nueve criterios: Predictiva, Relevante, Accionable, Genuina, Significativa, Precisa (Accurate), Oportuna (Timely), Independiente y Rentable (Cost). [web:46][web:48][web:54][web:51]

Se aplica sobre el universo MARGA-ENS: indicadores derivados del ENS y del modelo IMC de INCIBE para la mejora de la ciberresiliencia. [web:26][web:49][web:27][web:52]

2. GQM en clave MARGA-ENS

2.1. Niveles GQM

Siguiendo la literatura GQM, utilizamos tres niveles jerárquicos: [web:41][web:45][web:50]

1. Goal (Meta): objetivos estratégicos nacionales u organizativos (p. ej. “Aumentar la ciberresiliencia de los servicios esenciales”).
2. Question (Pregunta): cuestiones que ayudan a evaluar hasta qué punto se logra la meta (p. ej. “¿Con qué rapidez detectamos incidentes?”).
3. Metric (Métrica): datos observables que responden cuantitativamente a las preguntas (p. ej. “MTTD medio en horas”).

En el contexto IMC, las metas suelen ser de alto nivel (Anticipar, Resistir, Recuperar, Evolucionar), los dominios funcionales se traducen en preguntas, y las fichas de indicadores describen las métricas concretas. [web:33][web:49][web:27][web:52]

3. PRAGMATIC como metamétrica

3.1. Criterios PRAGMATIC

Tomamos como referencia la formulación de Brotby/Hinson y Kabay: [web:46][web:48][web:54][web:51]

- P – Predictive (Predictiva): ayuda a anticipar el futuro, no sólo a describir el pasado.
- R – Relevant (Relevante): guarda relación directa con metas y riesgos relevantes.
- A – Actionable (Accionable): permite tomar decisiones o priorizar acciones.
- G – Genuine (Genuina): se basa en datos reales, no en estimaciones arbitrarias.
- M – Meaningful (Significativa): es comprensible y aporta sentido a los interesados.
- A – Accurate (Precisa): suficientemente correcta para el uso previsto.
- T – Timely (Oportuna): disponible cuando se necesita para la decisión.
- I – Independent (Independiente): mínimamente susceptible a manipulación interesada.
- C – Cost-effective (Rentable): el coste de obtenerla no supera el valor que aporta.

Cada métrica MARGA-ENS será evaluada contra estos criterios mediante una escala 0–3 (0 = no cumple, 3 = cumple muy bien), generando un “score PRAGMATIC” total de 0–27.

4. Metas GQM de alto nivel para MARGA-ENS

A modo de esqueleto nacional, proponemos siete metas GQM:

4. G1 – Asegurar la adecuada implantación del ENS en las organizaciones obligadas.[web:26][web:19]
5. G2 – Incrementar la ciberresiliencia de los servicios esenciales según el modelo IMC.[web:49][web:27][web:52]
6. G3 – Mejorar la eficacia operativa de la función de ciberseguridad (detección, respuesta, recuperación).[web:33][web:20]
7. G4 – Evolucionar hacia arquitecturas Zero Trust acordes con las mejores prácticas internacionales.[web:6][web:14][web:10]
8. G5 – Consolidar una cultura de seguridad y continuidad medible.[web:49][web:52]
9. G6 – Gestionar el riesgo cibernético como riesgo empresarial, con cuantificación económica.[web:33][web:11][web:12]
10. G7 – Alinear la postura nacional con marcos europeos e internacionales de ciberseguridad y ciberresiliencia.[web:7][web:15][web:52]

A partir de ellas se derivan las preguntas y métricas que la encuesta MARGA-ENS explora.

5. Ejemplos de cadenas GQM por dominio

A continuación, algunos ejemplos representativos de cómo se estructura la cadena GQM en los indicadores clave del informe MARGA-ENS.

5.1. Gobernanza ENS y adecuación (G1)

Meta G1: Asegurar que las organizaciones obligadas han completado y mantienen el ciclo de adecuación ENS (alcance, categorización, DoA, implantación, auditoría, reporting).[web:26][web:19]

- Pregunta Q1.1: ¿Hasta qué punto se han categorizado los sistemas sujetos a ENS?
- Métrica M1.1.a: % de sistemas críticos categorizados según ENS (básico/medio/alto).
- Pregunta Q1.2: ¿En qué medida se ha formalizado la Declaración de Aplicabilidad (DoA)?
- Métrica M1.2.a: Estado de la DoA (0 = inexistente, 1 = parcial, 2 = completa sin aprobar, 3 = completa y aprobada).
- Pregunta Q1.3: ¿Cuál es el grado de implantación de las medidas ENS definidas en la DoA?
- Métrica M1.3.a: % de medidas ENS implantadas respecto a las planificadas.

5.2. Ciberresiliencia IMC (G2)

Meta G2: Aumentar la capacidad de **anticipar, resistir, recuperar y evolucionar** frente a ciberataques, según el modelo IMC de INCIBE.[web:49][web:27][web:33][web:52]

- Pregunta Q2.1: ¿Qué grado de utilización del modelo IMC existe en la organización?
- Métrica M2.1.a: Nivel de adopción IMC (0–3: desconocido, conocido, en piloto, implantado).
- Pregunta Q2.2: ¿Cómo de maduros son los indicadores de la meta Anticipar?
- Métrica M2.2.a: Índice de madurez IMC-Anticipar (0–100) según fichas IMC.
- Pregunta Q2.3: ¿Se miden tiempos de recuperación y continuidad para la meta Recuperar?
- Métrica M2.3.a: % de servicios esenciales con pruebas de recuperación exitosas dentro de RTO.

5.3. Eficacia operativa (G3)

Meta G3: Reducir tiempos de detección, respuesta y recuperación, así como la frecuencia e impacto de incidentes.[web:33][web:20][web:21]

- Pregunta Q3.1: ¿Cuál es el tiempo medio de detección de incidentes significativos?
- Métrica M3.1.a: MTTD (Media de Tiempo de Detección) en minutos/horas.
- Pregunta Q3.2: ¿Cuál es el tiempo medio de respuesta y contención?
- Métrica M3.2.a: MTTR (Media de Tiempo de Respuesta) en minutos/horas.
- Pregunta Q3.3: ¿Qué eficacia muestra el programa de gestión de vulnerabilidades?
- Métrica M3.3.a: Tiempo medio de parcheado de vulnerabilidades críticas.
- Métrica M3.3.b: % de vulnerabilidades críticas resueltas dentro de SLA.

5.4. Zero Trust (G4)

Meta G4: Transicionar progresivamente a un modelo Zero Trust, reduciendo confianza implícita en perímetros y reforzando controles basados en identidad y contexto.[web:6][web:10][web:14]

- Pregunta Q4.1: ¿Cuál es el grado de protección de recursos críticos con MFA y controles contextuales?
- Métrica M4.1.a: % de recursos críticos accesibles sólo mediante MFA.
- Pregunta Q4.2: ¿Hasta qué punto se monitorizan y controlan los accesos este-oeste?
- Métrica M4.2.a: % de segmentos de red con registros de tráfico completos y analizados.

5.5. Cultura y continuidad (G5)

Meta G5: Desarrollar una cultura de seguridad y continuidad basada en formación, concienciación y pruebas periódicas.[web:26][web:49][web:52]

- Pregunta Q5.1: ¿Cuál es el alcance real del programa de formación?
- Métrica M5.1.a: % de personal que ha completado formación anual obligatoria.
- Pregunta Q5.2: ¿Se prueban los planes de continuidad y recuperación?
- Métrica M5.2.a: Frecuencia de pruebas de BCP/DRP (ejercicios/año).
- Métrica M5.2.b: % de pruebas que cumplen los RTO/RPO establecidos.

5.6. Riesgo y ROI (G6)

Meta G6: Gestionar el riesgo cibernético como riesgo empresarial, articulando cuantificación económica básica.[web:33][web:11][web:12]

- Pregunta Q6.1: ¿Se estima la pérdida anual esperada por incidentes?
- Métrica M6.1.a: Pérdida anual esperada estimada (€).
- Pregunta Q6.2: ¿Qué proporción del presupuesto TI se destina a ciberseguridad?
- Métrica M6.2.a: % presupuesto TI dedicado a ciberseguridad.
- Pregunta Q6.3: ¿Se aproxima el retorno de la inversión en ciberseguridad?
- Métrica M6.3.a: ROI estimado = (Pérdida evitada – inversión) / inversión.

6. Evaluación PRAGMATIC de las métricas MARGA-ENS

Para cada métrica Mx.y.z definida en el informe MARGA-ENS se propone:

11. Completar una pequeña ficha PRAGMATIC con calificación 0–3 en cada criterio (P, R, A, G, M, A, T, I, C).
12. Calcular el PRAGMATIC Score total.
13. Definir umbrales para distinguir métricas “estrella”, “aceptables” y “candidatas a jubilación”.

Ejemplo (en abstracto):

- M3.1.a – MTTD medio
- P: 3 (muy buen indicador para anticipar impacto futuro).
- R: 3 (directamente ligado a la eficacia de detección).
- A: 3 (permite priorizar inversiones en detección).
- G: 2 (depende de la calidad de los registros).
- M: 3 (fácil de entender).
- A: 2 (precisión suficiente si la medición es homogénea).
- T: 2 (si se calcula al menos mensualmente).
- I: 2 (moderada independencia: podría maquillarse si no se define bien “incidente”).
- C: 3 (bajo coste si ya existen SIEM/SOC).
- Total: 22/27.

En los documentos siguientes se ofrece una matriz más completa.

7. Procedimiento de uso

14. Definir metas GQM nacionales/organizativas (G1–G7 como base, adaptables).
15. Derivar preguntas para cada meta (Qx.y) alineadas con ENS, IMC y marcos afines.
16. Asociar métricas concretas (Mx.y.z) relacionadas con la encuesta MARGA-ENS.
17. Evaluar cada métrica con PRAGMATIC, revisando si merece la pena mantenerla, mejorarla o eliminarla.
18. Usar sólo métricas con buena puntuación PRAGMATIC como insumo para IGM, ROI y cuadros de mando estratégicos.

El resultado es un marco que conecta objetivos nacionales con datos técnicos sin perderse en la jungla de los logs ni en el purgatorio de los PowerPoints.